

Guide de la double authentification et de l'anti-phishing

VerroulA · Kit de protection · septembre 2026

Ce guide répond à deux questions : comment verrouiller vos comptes avec la double authentification, et comment votre équipe peut reconnaître les pièges envoyés par courriel, SMS, code QR ou téléphone. Il est écrit pour un dirigeant de TPE ou de PME, sans prérequis technique. Les actions décrites se réalisent cette semaine.

Pourquoi la double authentification change tout

La double authentification, aussi appelée MFA, ajoute une deuxième épreuve après le mot de passe : quelque chose que vous possédez (téléphone, application, clé physique) ou quelque chose que vous êtes (empreinte, visage). Un attaquant qui vole votre mot de passe se retrouve bloqué sans la deuxième preuve.

La grande majorité des prises de contrôle de comptes reposent sur des identifiants volés ou réutilisés. La double authentification coupe la route à l'essentiel de ces attaques. Elle ne protège pas contre tout, mais elle transforme un compte ouvert à clé en compte fermé à double tour.

Les trois formes de double authentification

1. Le code reçu par SMS. C'est la forme la plus simple. Elle reste vulnérable au détournement de numéro et doit être réservée aux services qui ne proposent rien de mieux. Mieux que rien, mais à dépasser dès que possible.
2. L'application d'authentification sur le téléphone. Elle génère un code à durée courte, sans passer par le réseau téléphonique. C'est la solution recommandée pour l'essentiel des services professionnels.
3. La clé de sécurité physique. Petite clé à brancher sur l'appareil, elle est la forme la plus robuste. Réservez-la aux comptes critiques : messagerie principale, banque, compte administrateur.

À éviter : les questions de sécurité du type « nom de jeune fille de votre mère », et les codes envoyés par courriel. Si la boîte mail est compromise, tous les comptes qui s'en servent pour se réinitialiser le sont aussi.

Par où commencer : l'ordre de déploiement en TPE

Commencez par la messagerie. Votre boîte mail commande presque tout : c'est par elle que passent les réinitialisations de mots de passe, les factures, les accès aux autres services. Un attaquant qui contrôle la messagerie contrôle souvent toute l'entreprise.

1. Messagerie professionnelle : activez la double authentification cette semaine.
2. Banque en ligne : activez l'application ou la clé demandée par votre établissement, désormais exigée par la plupart des banques pour les virements.
3. Comptes d'administration : hébergement du site, nom de domaine, espace cloud professionnel, logiciels de gestion, comptabilité.
4. Ensuite seulement : réseaux sociaux professionnels, messageries internes, espaces fournisseurs.

Chaque activation prend de 5 à 15 minutes. Comptez une matinée pour couvrir l'essentiel de l'entreprise. Notez dans votre coffre de mots de passe la méthode retenue pour chaque service.

Ce qu'est le phishing

Le phishing, ou hameçonnage, est un message conçu pour vous faire agir : cliquer sur un lien, ouvrir une pièce jointe, saisir un identifiant, payer une fausse facture ou transférer de l'argent. Le message imite une personne ou une organisation de confiance et fabrique l'urgence.

En 2026, ces messages sont plus difficiles à repérer qu'auparavant. Les outils d'IA permettent de rédiger un français sans fautes, d'imiter le style d'un collègue et de fabriquer des documents d'apparence officielle. Le vieux réflexe « c'est plein de fautes, donc c'est une arnaque » ne suffit plus.

Les formes les plus fréquentes en 2026

L'usurpation du dirigeant. Un message signé du dirigeant, envoyé depuis une adresse qui ressemble à la sienne, demande un virement urgent, des relevés de comptes ou l'achat de cartes cadeaux. Le prétexte classique : « Je suis en réunion, je ne peux pas vous appeler. » La pression et la demande de secret sont les deux drapeaux rouges.

Le faux fournisseur. Une facture modifiée, un fournisseur qui annonce un changement de numéro de compte, une relance de paiement agressive. Tout changement de coordonnées bancaires reçu par courriel se vérifie par téléphone, sur un numéro connu, jamais sur celui du message.

Le QRishing. Des codes QR piégés, posés sur une affiche, un flyer, un faux avis de passage, ou glissés dans un courriel. Le code ouvre un site qui imite une page connue. Avant de scanner, regardez où mène le code et vérifiez l'adresse du site affichée dans votre navigateur.

Le deepfake vocal. Avec l'IA, quelques secondes d'enregistrement suffisent pour imiter une voix. Un appel « du dirigeant » demande un virement d'urgence ; la voix ressemble à la sienne, mais la demande reste anormale. Règle absolue : tout ordre de paiement passé par téléphone est confirmé par un second canal, sur un numéro connu.

Le faux support et les fausses alertes. Un « service informatique » demande votre mot de passe, une « alerte de sécurité » vous invite à cliquer sans réfléchir. Aucun service légitime ne demande un mot de passe complet, par aucun canal.

Les signaux qui doivent déclencher la méfiance

- L'urgence et la menace : compte bloqué, virement imminent, amende, rupture de contrat.
- La demande de secret : « ne parlez de ce projet à personne ».
- Le changement d'habitude : premier message d'un fournisseur, nouvelle adresse, nouveau format, nouvelle signature.
- Une adresse d'expéditeur qui imite une adresse connue : votre-societe.com au lieu de votre-societe.fr.
- Une pièce jointe inattendue ou un lien vers une page de connexion.
- Une demande de mot de passe ou de code, quel qu'en soit le prétexte.

La règle d'or : vérifier par un autre canal

Quand un message demande de l'argent, des identifiants ou un acte inhabituel, on vérifie par un canal différent : appel sur un numéro connu, visite au bureau du collègue, page officielle du fournisseur. La vérification prend deux minutes. Un virement frauduleux, lui, ne se rattrape pas toujours.

Un salarié a cliqué : la procédure

Le bon réflexe d'équipe : celui qui clique n'est pas coupable d'être humain. Il serait fautif de se taire. Une réponse rapide limite les dégâts ; la honte les aggrave.

1. Prévenir immédiatement. Dans l'heure, le salarié informe le dirigeant ou le référent sécurité, même sans certitude d'avoir été piégé.
2. Changer les mots de passe. Le mot de passe du compte concerné est changé depuis un autre appareil, de même que celui de tout compte utilisant le même identifiant. Déconnectez les sessions actives.
3. Prévenir la banque sous 48 heures au plus tard dès qu'une information bancaire ou un paiement est en cause. Signalez le virement frauduleux et demandez les mesures de rappel ou d'opposition. Même sans mouvement constaté, la banque doit être informée.
4. Consigner l'incident. Notez la date, l'heure, le canal (courriel, SMS, appel, code QR), la nature du message, les comptes touchés et les actions menées. Ce relevé sert à corriger, à prouver votre réactivité et à améliorer la formation.
5. Analyser et signaler. Si l'incident touche des données personnelles de clients ou de salariés, l'entreprise doit examiner si la violation doit être notifiée à la CNIL, dans le délai de 72 heures prévu par le règlement général sur la protection des données. Signalez aussi l'incident aux autorités compétentes et à votre assureur si vous disposez d'une assurance cyber.

Former l'équipe sans la terroriser

Une session de 30 minutes par an suffit pour poser les bases : la règle d'or de la vérification, les formes d'attaques de l'année, et la procédure « un salarié a cliqué ». Terminez toujours par la même phrase : celui qui prévient vite est un atout, celui qui se tait est un risque.

Testez une fois par an avec un faux message interne, puis débriefez collectivement, sans sanctionner personne. L'exercice apprend plus qu'une heure de théorie.

En résumé

- La double authentification s'active d'abord sur la messagerie, la banque et les comptes administrateurs : une matinée suffit.
- En 2026, un message propre et bien rédigé peut être une arnaque : vérifiez toujours par un autre canal avant d'agir.
- Tout ordre de paiement ou changement de coordonnées bancaires se confirme par téléphone, sur un numéro connu.
- Celui qui a cliqué prévient dans l'heure, change ses mots de passe, alerte la banque sous 48 heures et consigne l'incident.